

The Maintenance menu and routes are not permission-gated

The Maintenance section’s visibility is hardcoded per role and its routes open by URL for anyone, because **no permission exists to control it**. One root cause, two symptoms.

MEDIUM

Env QA · V1.36

acme.qa.egalvanic.ai

Web

ROOT CAUSE

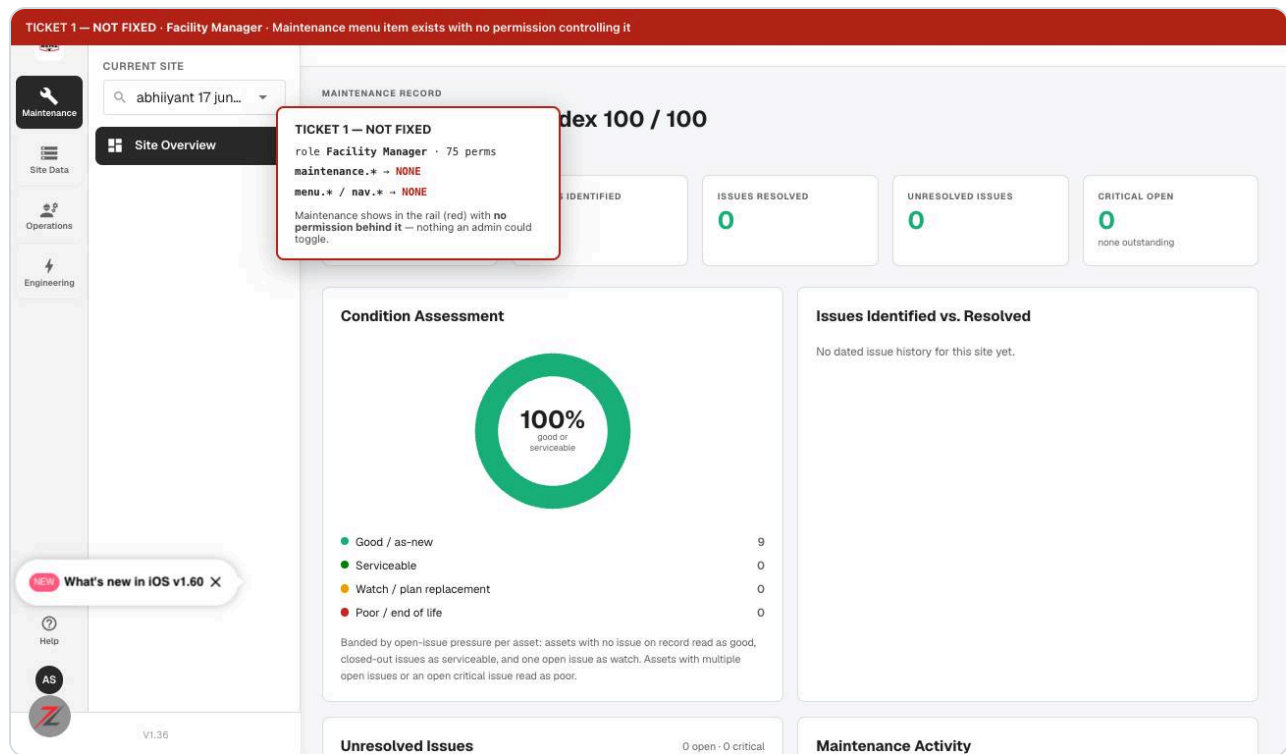
No maintenance.* permission exists for any role. Live /api/auth/v2/me, checked across Admin, Facility Manager, Client Portal and Project Manager:

```
permissions matching maintenance.* → NONE (every role)
permissions matching menu.* / nav.* → NONE (every role)
```

With no permission to check, nothing gates the Maintenance nav item or its routes. Both symptoms below follow from this.

SYMPTOM 1 · navigation

The Maintenance menu item is hardcoded, not permission-driven



The **Maintenance** rail item (red) shows for Facility Manager with no permission behind it. It appears for Client Portal + FM and is absent for Admin, PM, Account Manager and Technician — driven by hardcoded rules, not the permission matrix.

ACTUAL

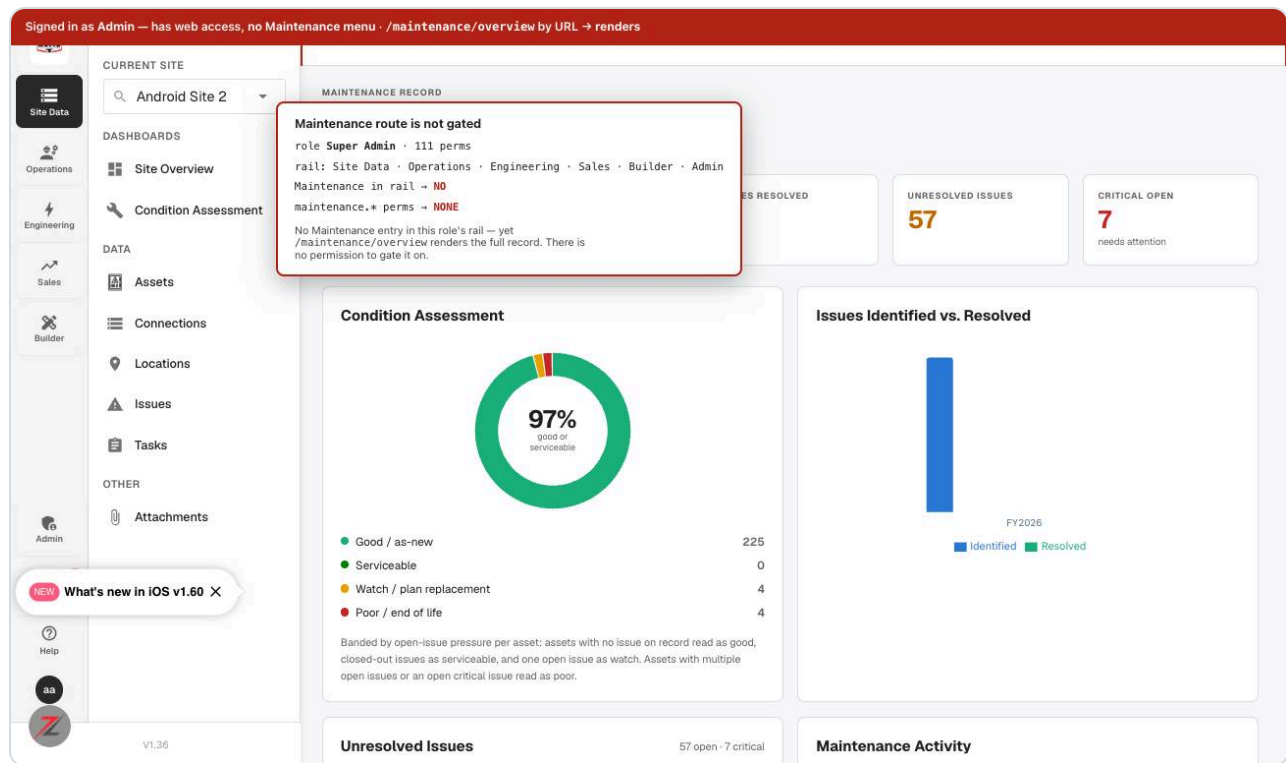
Which roles see Maintenance is fixed in code. An admin cannot show or hide it per role from the role-permission screen — it would take a code change and deploy.

EXPECTED

Visibility is driven by a permission an admin can toggle per role, with no deploy.

SYMPTOM 2 · routing

The routes open by direct URL for every role



Admin — has web access, and the rail has **no Maintenance entry**. Yet /maintenance/overview by URL renders the full record (233 assets, 57 unresolved, 7 critical).

re-verified live 2026-08-27, roles WITH web access but NO Maintenance nav entry:

Admin	/maintenance/overview → renders	/maintenance/program → renders
Account Manager	/maintenance/overview → renders	/maintenance/program → renders
Project Manager	/maintenance/overview → renders	/maintenance/program → renders
Technician	n/a — now blocked earlier by the web-access gate (platform.web removed), so it cannot demonstrate this bug	

ACTUAL

Every web-enabled role with no Maintenance nav entry — Admin, Project Manager, Account Manager — can type /maintenance/overview or /maintenance/program and the page renders in full.

EXPECTED

Roles without the Maintenance permission get **ACCESS DENIED** on these routes, the way other gated routes already behave.

Severity note — not a data leak. /maintenance/overview repackages a site's assets, issues and condition — data internal roles can already reach via /assets and /issues, and for Client Portal it is their own site. So nobody sees data they otherwise couldn't. This is a **configurability / design-intent gap** (the

section can't be managed from the permission matrix), not a security exposure. Sized **Medium** on that basis.

Steps to reproduce

- 1 Sign in as a **web-enabled** role that has no Maintenance nav entry — the Admin account, Project Manager or Account Manager. **Not** the Technician: it no longer has web access at all, so it stops at the web-access gate before this bug is reachable.
- 2 Confirm there is no **Maintenance** item anywhere in the left rail.
- 3 In the address bar, go to `/maintenance/overview` (and `/maintenance/program`).
- 4 The page renders the full record — 233 assets, condition index, unresolved issues, activity log.
- 5 In the console, `fetch('/api/auth/v2/me')` → no permission name contains maintenance.

Acceptance criteria for the fix

- ☐ A permission (e.g. `features.maintenance.view`) exists and gates the Maintenance nav item.
- ☐ The same permission gates `/maintenance/overview` and `/maintenance/program` at the route level — roles without it get Access Denied by URL.
- ☐ Existing access is preserved: the permission is granted to the roles that see Maintenance today (Client Portal, Facility Manager), so there is no regression.
- ☐ An admin can toggle the permission per role from the role-management screen with no code deploy.

Duplicate / link note. This is the same underlying gap as the earlier **Bug 3a** (Maintenance routes not gated) and is the concrete instance of the open ticket **“Make all menu options permission-based”**. If that ticket is being worked, this bug closes with it — link them rather than fixing twice.

Verified live on QA, 27 Aug 2026. Signed in per role through the login form, cookies and storage cleared between roles. No data created, edited or deleted.